

CENTRA YAZILIM A.Ş.

GMS — Kurumsal Yönetişim ve Release Management Platformu

Proje İlerleme, Teknik Mimari ve Yol Haritası
Raporu

Hazırlayan	Mahir Furkan Dalyan
Kurum / Staj	CENTRA YAZILIM A.Ş.
Tarih	16 Temmuz 2026
Sürüm	1.0
Durum	Aktif Geliştirme (Active Development)

Bu belge teknik bir mentöre yönelik hazırlanmış bir proje ilerleme raporudur. İçerik, deponun (repository) güncel durumu — kaynak kod, veritabanı göçleri (migrations), otomatik testler ve proje yapısı — incelenerek doğrulanmıştır. Belge, ürünün tam üretime hazır

(production-ready) veya resmî GxP doğrulaması yapılmış olduğunu iddia etmez.

İÇİNDEKİLER

İçindekiler

— Yönetici Özeti

1 Proje Tanımı

2 Proje Hedefleri

3 Teknoloji Yığını (Technology Stack)

4 Mimari Yaklaşım

5 Tamamlanan Backend Alanları (Domains)

6 Frontend Durumu

7 Uçtan Uca İş Akışı

8 Paylaşılan Platform Yetenekleri

9 Veritabanı ve Veri Bütünlüğü

10 Güvenlik Kontrolleri

11 Test ve Kalite Sonuçları

12 Çözülen Önemli Teknik Problemler

13 Güncel Proje Durumu

14 Sonraki Geliştirme Planı (Yol Haritası)

15 Riskler ve Açık Maddeler

16 Kişisel Katkı ve Öğrenimler

17 Mentör ile Tartışma Konuları

18 Sonuç

EK Teknik Kanıtlar

— Yönetici Özeti

GMS (Governance Management System), başlangıçta bir **Release Management** (yayın yönetimi) platformu olarak tasarlanmış; zamanla **modüler bir kurumsal yönetim platformuna** dönüşmüştür. Bugün, gerçek bir backend yaşam döngüsünü kapsamaktadır: **Change (Değişiklik) → Workflow (İş Akışı) → Release (Yayın) → Execution (Yürütme) → Validation (Doğrulama)**.

- Kimlik/RBAC, Doküman Yönetimi, Bildirim Motoru, Birleşik Denetim (Unified Audit), Raporlama, Entegrasyon Merkezi (Integration Hub) ve Arka Plan İşleme (Background Processing), tüm alanların ortak kullandığı **paylaşılan platform servisleri** olarak geliştirildi.
- Backend, **gerçek SQL Server** üzerinde çalışır; çekirdek yaşam döngüsü uçtan uca doğrulanmıştır.
- Angular tarafında **kimlik doğrulama (authentication) temeli** gerçek backend'e bağlanmış; ardından **Change ve İş Akışı Görevleri (Workflow Tasks)** modülleri de gerçek API'ye entegre edilerek uçtan uca doğrulanmıştır.
- Şu anki aktif faz, **özellik-özellik (feature-by-feature) Angular entegrasyonudur**; kalan modüller kademeli olarak taşınmaktadır.
- Ürün, **henüz tam üretime hazır (production-ready) veya GxP doğrulaması yapılmış olarak sunulmamaktadır**; bunlar sonraki fazların konusudur.

Bu rapor boyunca ilerleme durumu dört ayrı sınıfta netleştirilmiştir: **Tamamlandı ve Doğrulandı**

Backend Hazır / Frontend Bekliyor

Kısmen Tamamlandı

Planlandı / Kapsam Dışı

1 Proje Tanımı

GMS, bir kurumun yazılım ve altyapı üzerinde yaptığı **değişiklikleri** baştan sona kontrollü, izlenebilir ve onaya dayalı bir şekilde yönetmesini sağlayan bir **yönetişim platformudur**. Basit bir dille: "Bir şeyi değiştirmeden önce kim talep etti, kim onayladı, ne zaman, hangi risklerle ve hangi kanıtlarla uygulandı?" sorularının tamamının kayıt altında olmasını sağlar.

Temel Kavramlar

- **Governance Management (Yönetişim Yönetimi):** Değişikliklerin keyfi değil, tanımlı kurallar, roller ve onay süreçleri içinde yürütülmesi.
- **Change Management (Değişiklik Yönetimi):** Bir değişiklik talebinin oluşturulması, risk/hazırlık değerlendirmesi, revizyonlanması ve incelemeye gönderilmesi.
- **Release Management (Yayın Yönetimi):** Onaylanmış değişikliklerin bir yayın planı (release plan) altında gruplanıp planlanması.
- **Workflow Management (İş Akışı Yönetimi):** Onay ve görev adımlarının, sürümlenmiş (versioned) iş akışı tanımlarıyla otomatik yürütülmesi.
- **Execution (Yürütme):** Onaylı değişikliğin hedef ortama adım adım uygulanması ve gerektiğinde geri alınması (rollback).
- **Validation (Doğrulama):** Uygulama sonrası kontrol/kanıt kayıtlarıyla sonucun kabul edilmesi.

Kimler Kullanır?

Değişiklik talep edenler (Requester), mimarlar (Architect), kalite uzmanları (QA), yayın yöneticileri (Release Manager), uygulayıcılar (Executor), doğrulayıcılar (Validator), denetçiler (Auditor) ve yöneticiler (Admin). Özellikle **düzenlemeye tabi (regülasyonlu) sektörlerde** —örneğin ilaç/GxP— kontrollü değişiklik ve tam izlenebilirlik zorunludur.

Önlediği Problemler

- Kontrolsüz değişiklikler
- Eksik onaylar
- Belirsiz sorumluluk
- Yayın (release) riskleri
- Kayıt altına alınmamış dağıtım adımları
- Eksik doğrulama kanıtı
- Zayıf izlenebilirlik (traceability)
- Kopuk dokümanlar
- Dağınık bildirimler
- Eksik denetim izleri (audit trail)

Somut Örnek. Bir şirket, üretime (production) bir *veritabanı + uygulama* değişikliği çıkmak istiyor. GMS'te akış şöyle işler: Requester bir **Change** oluşturur (etkilenen varlıklar, SQL/rollback betiği, iş gerekçesi); backend **risk ve hazırlık** puanını hesaplar; Change **incelemeye gönderilince** ilgili **iş akışı** başlar ve mimar (Architect) onayına düşer; onay sonrası Change **Approved** olur; bir **Release Plan**'a alınır; **Execution** ile adım adım uygulanır; **Validation** ile kanıtlar toplanır ve sonuç kabul edilir. Her adım, gerçek aktör adlarıyla **denetim kaydına** yazılır.

2 Proje Hedefleri

Hedef	Açıklama
Tek doğruluk kaynağı (Single source of truth)	Tüm yönetim verisi backend'te; frontend yalnızca görüntüler/işletir.
Kontrollü yaşam döngüsü	Durum geçişleri (status transitions) kurallarla korunur; keyfi atlamalar engellenir.
Rol tabanlı yetkilendirme (RBAC)	Her işlem, izin (permission) ve rol bazında backend'te zorlanır.
Tam izlenebilirlik	Append-only (yalnızca ekleme) denetim kayıtları ve birleşik zaman çizelgesi.
Yeniden kullanılabilir platform servisleri	Audit, Notification, Workflow, Documents, Integration her alan tarafından paylaşılır.
Modüler büyüme	Yeni alan, mevcut mimariyi bozmadan eklenebilir (modüler monolit).
Entegrasyona hazırlık	Sağlayıcı (provider) tabanlı Integration Hub ile dış sistemlere açık.
GxP / farmasötik hazırlık temeli	Kontrollü değişiklik, denetim ve iş akışı temeli kurulmuştur.
Gelecekteki yapay zekâ (AI) yetenekleri	Güvenilir veri + iş akışı üzerine inşa edilecek sonraki katman.

Mevcut çalışma **teknik temeli** kurmaktadır. **Resmî regülasyon doğrulaması (GxP validasyonu)** ayrı ve sonraki bir fazdır; bu raporda tamamlanmış olarak sunulmaz.

3 Teknoloji Yığını (Technology Stack)

Aşağıdaki teknolojiler depo incelenerek doğrulanmıştır (yalnızca fiilen mevcut olanlar listelenmiştir).

Backend

- ASP.NET Core 8 (Web API)
- Entity Framework Core (ORM / Unit-of-Work)
- SQL Server 2022 (gerçek ilişkisel veritabanı)
- JWT tabanlı kimlik doğrulama
- ASP.NET Core Data Protection (sır/gizli anahtar koruması)
- `BackgroundService` tabanlı worker altyapısı
- OpenTelemetry (izleme/metrik)
- xUnit + `WebApplicationFactory` (entegrasyon testleri)
- Swagger / OpenAPI (geliştirme ortamında)
- ASP.NET Core Rate Limiting (hız sınırlama)

Frontend

- Angular 22
- Standalone bileşenler (components)
- Signals (reaktif durum)
- RxJS (akış/asenkron)
- Fonksiyonel interceptor ve guard'lar
- Transloco (i18n — TR/EN)
- Vitest (birim testleri)
- Mevcut kurumsal tasarım sistemi (design system)

Altyapı

- Docker / Docker Compose
- SQL Server container (`mcr.microsoft.com/mssql/server:2022`)
- Yerel dosya depolama soyutlaması (`IFileStorage` / `LocalFileStorage`)
- Gerçek SQL Server entegrasyon-test veritabanı

4 Mimari Yaklaşım

GMS, **modüler monolit (modular monolith)** olarak tasarlanmıştır: tek bir dağıtılabılır uygulama içinde, alan-odaklı (domain-oriented) modüller net sınırlarla ayrılır.

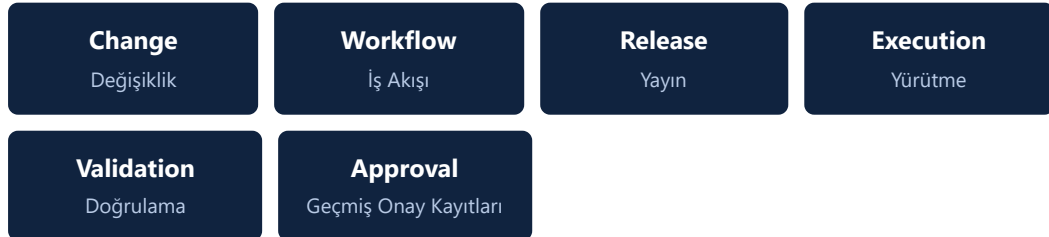
- **İnce controller'lar (thin controllers):** HTTP uçları küçüktür; iş mantığı servis katmanındadır.
- **Servislerde iş mantığı:** Risk, hazırlık, iş akışı yürütmesi, entegrasyon dağıtımı gibi kurallar servislerde.
- **EF Core kalıcılık/Unit-of-Work:** Kayıtlar tek transaction içinde tutarlı yazılır.
- **DTO sınırları:** Dış dünyaya varlıklar (entities) değil, DTO'lar döner.
- **Backend sistem-kaydı (system of record):** Doğruluk kaynağı backend'tir.
- **JWT + izin tabanlı RBAC:** Yetkilendirme policy'lerle backend'te zorlanır.
- **İyimser eşzamanlılık (optimistic concurrency):** `RowVersion` ile kayıp güncelleme (lost update) tespiti (409).
- **Korumalı durum geçişleri:** Geçersiz durum atlamaları engellenir.
- **Append-only denetim:** Denetim kayıtları eklenir, değiştirilmez.
- **Merkezî bildirim, sürümlü iş akışı motoru, sağlayıcı tabanlı entegrasyon, arka plan worker'ları + outbox'a hazır işleme.**

Neden Mikroservis / Kafka / CQRS / Event Sourcing Kullanılmadı?

Bu aşamada ürün, **tek ekip tarafından hızlı ve güvenilir biçimde** geliştirilmekte ve doğrulanmaktadır. Mikroservisler, Kafka gibi mesaj kuyrukları, CQRS framework'leri ve Event Sourcing; operasyonel karmaşıklık, dağıtık transaction ve gözlemlenebilirlik maliyeti getirir. Mevcut ölçekte bunlar **erken optimizasyon** olurdu. Bunun yerine mimari **kasıtlı olarak pragmatik ve genişletilebilir** tutuldu: entegrasyon ve bildirim kayıtları *outbox'a hazır* tasarlandı; ilerleyen fazlarda gerçek bir mesaj altyapısına veya servis ayrıştırmasına geçiş, mevcut sınırlar korunarak yapılabilir.

Şekil 1 — GMS Modül Mimarisi

Çekirdek Yaşam Döngüsü Modülleri



Paylaşılan Platform Servisleri



Reporting

Raporlama

Integration Hub

Entegrasyon

Background/Workers

Arka Plan

Observability

Gözlemlenebilirlik

Tüm çekirdek modüller, alttaki paylaşılan platform servislerini yeniden kullanır.

5 Tamamlanan Backend Alanları (Domains)

Aşağıdaki alanların tümü backend'te tamamlanmış ve gerçek SQL Server üzerinde otomatik testlerle doğrulanmıştır. Frontend entegrasyon durumu ayrıca **Bölüm 6 ve 13**'te belirtilir.

5.1 Change Management Backend + Frontend Entegre

Amaç: Değişiklik taleplerinin kontrollü yönetimi. **Ana varlıklar:** ChangeRequest, ChangeRevision, ChangeAffectedAsset, ChangeDocument, ChangeAuditEvent. **Yaşam döngüsü:** Draft → Submitted → UnderReview → Approved → Scheduled → Implemented (ve Cancelled). **İş kuralları:** risk ve hazırlık (readiness) backend'te hesaplanır; kritik hazırlık bulgusu olan bir değişiklik gönderilemez; revizyon numarası artar; durum geçişleri korunur. **API:** list/detail/create/update/submit/cancel/revisions/audit. **Entegrasyon:** submit anında Workflow Engine tetiklenir. **Durum:** uçtan uca doğrulandı.

5.2 Approval Management Geçmiş Kayıt (okunur)

Amaç: Onay kararları ve imza anlamı (signature meaning) kayıtları. Başlangıçta onay orkestrasyonu ApprovalService ile yapılıyordu; **Workflow Stratejisi A** benimsendikten sonra yeni Change gönderimlerinin orkestrasyon sahipliği **Workflow Engine'e** devredildi. Mevcut ApprovalRequest kayıtları **okunabilir** kalır (geçmiş). Böylece **iki rakip aktif onay motoru bulunmaz**; yeni onaylar iş akışı görevidir.

5.3 Release Planning Backend Hazır / Frontend Bekliyor

Varlıklar: ReleasePlan ve bağlı değişiklikler. **Kurallar:** yalnızca *Approved* değişiklikler; aynı müşteri/proje/ortam kısıtı; risk hesabı; planlama ve iptal; Change durum entegrasyonu (Scheduled). **Durum:** backend tamam, gerçek DB testli; frontend mock.

5.4 Execution / Deployment Backend Hazır / Frontend Bekliyor

Varlıklar: DeploymentRun ve sıralı DeploymentStep'ler. **Yetenekler:** adım sırası, başarı/başarısızlık, geri alma (rollback), Release ve Change durum entegrasyonu. **Durum:** backend tamam; frontend mock.

5.5 Validation Backend Hazır / Frontend Bekliyor

Varlıklar: ValidationRun, kontroller (checks), kanıt (evidence) metası. **Kurallar:** geç/başarısız (pass/fail), Release kabulü; **doğrulama başarısızlığında otomatik rollback yapılmaz** (bilinçli karar). **Durum:** backend tamam; frontend mock.

5.6 Identity, Authentication & RBAC Backend + Frontend Entegre

Yetenekler: gerçek e-posta/parola girişi, parola hash'leme, JWT access token, refresh-token rotasyonu, hesap kilitleme (logout), roller, izinler, `ICurrentUser`, backend

yetkilendirme zorlaması, güvenlik denetimi, hız sınırlama. **Durum:** backend + frontend tam entegre; uçtan uca doğrulandı.

5.7 Document Management Backend Hazır / Frontend Bekliyor

Yetenekler: paylaşılan doküman sistemi, sürümleme, SHA-256 bütünlük, indirme doğrulaması, soft delete (yumuşak silme), alan nesnelere bağlama, depolama soyutlaması (`IFileStorage`) + `LocalFileStorage` . **Sınırlamalar:** antivirüs/bulut depolama entegrasyonu henüz yok. **Durum:** backend tamam; frontend mock.

5.8 Notification Engine Backend Hazır / Frontend Bekliyor

Yetenekler: uygulama-içi (in-app) + e-posta teslim modeli, şablonlar, kullanıcı tercihleri, rol/kullanıcı/broadcast bildirimleri, okundu/arşiv, arka plan e-posta teslimi, geliştirmede dummy sağlayıcı. **Durum:** backend tamam; frontend mock.

5.9 Unified Audit & Reporting Backend Hazır / Frontend Bekliyor

Yetenekler: alan denetim tabloları yetkilidir; birleşik okuma görünümü (SQL view) / birleşik zaman çizelgesi; operasyonel raporlar; CSV dışa aktarım + CSV injection koruması; izinle korunan güvenlik raporlaması. **Durum:** backend tamam; frontend mock.

5.10 Workflow Engine Backend + Görev UI Entegre

Yetenekler: sürümlü tanımlar, yayımlanmış sürümlerin değişmezliği (immutable), örnekler (instances), rol/kullanıcı ataması, koşullar (conditions), duraklat/süzdür/iptal, bildirimler, Change entegrasyonu; Standard/Normal/Emergency tohumlanmış (seeded) iş akışları. Workflow, **güncel Change orkestrasyon kaynağıdır**. **Durum:** backend tamam; "İş Akışı Görevleri" (Görevlerim) ve örnek/görev detayı frontend'e entegre ve uçtan uca doğrulandı; iş akışı tasarımcısı (designer) ekranı hâlâ mock.

5.11 Integration Hub Backend Hazır / Frontend Bekliyor

Yetenekler: sağlayıcı/adaptör mimarisi, Generic REST, gelen/giden webhook, Jira/Azure DevOps sandbox sağlayıcıları, sır şifreleme (secret encryption), retry/dead-letter, dış nesne bağları (external object links), SSRF/webhook güvenliği, outbox'a hazır `IntegrationExecution` kaydı. **Durum:** backend tamam; frontend bağlanmadı.

5.12 Background Processing & Observability

Backend Hazır / Frontend Bekliyor

Worker'lar: IntegrationDispatchWorker, NotificationDeliveryWorker, WorkflowSlaWorker, OperationalCleanupWorker (ortak `BackgroundWorkerBase`); WorkerHeartbeat, retry/backoff. **Gözlemlenebilirlik:** Correlation ID, yapılandırılmış loglama (structured logging), OpenTelemetry, sağlık uçları (`/health/live` , `/health/ready`), operasyonel durum ucu. **Durum:** backend tamam; operasyon paneli frontend'e bağlanmadı.

6 Frontend Durumu

Frontend durumu, backend durumundan **net biçimde ayrılmalıdır**. Aşağıdaki tablo deponun güncel hâlini yansıtır.

Tamamlanan (gerçek backend'e bağlı, doğrulanmış)

- Gerçek giriş (login), JWT, refresh rotasyonu
- Oturum geri yükleme (session restoration)
- Auth durumu (signal tabanlı)
- İzin/rol guard'ları + `*gmsHasPermission` direktifleri
- Logout / logout-all, parola değiştirme
- 401/403 yönetimi (403 oturumu düşürmez)
- Normalize API hata modeli (`ApiError`)
- Merkezî API URL (`API_BASE_URL`)
- Change modülü** (liste/detay/sihirbaz) — gerçek API
- Workflow Görevleri** (Görevlerim + örnek/görev detayı) — gerçek API

Angular **production derlemesi 0 hata / 0 uyarı; 42 birim testi** yeşildir. Change ve Workflow lifecycle (oluştur → gönder → onay → Approved) gerçek backend'e karşı tarayıcı ile uçtan uca doğrulanmıştır.

Hâlâ mock/localStorage veya henüz tam entegre değil

Modül	Frontend Durumu
Release Planning	Mock / entegre değil
Execution	Mock / entegre değil
Validation	Mock / entegre değil
Documents	Mock / entegre değil
Notifications	Mock / entegre değil
Audit / Reports	Mock / entegre değil
Integrations	Mock / entegre değil
Operations (operasyon paneli)	Mock / entegre değil
Workflow Designer (tanım tasarımcısı)	Mock / entegre değil
Approval sayfası	Mock — "Geçmiş Kayıt" etiketli

Not: Release ve Reports ekranları hâlâ eski bir mock `ChangeService` 'ten beslenmektedir; bu, ilgili modüller taşınana kadar kalan bilinçli bir geçiş durumudur. Change/Workflow ekranları bu mock'a bağlı değildir.

Frontend modülleri, **riskli bir topyekûn yeniden yazımdan (big-bang rewrite) kaçınmak için kademeli (incremental)** olarak gerçek API'ye taşınmaktadır. Paylaşılan temel (auth, interceptor'lar, `ApiError`, `PagedResult`, guard/direktifler) hazır olduğundan her modül düşük riskle bağlanabilmektedir.

7 Uçtan Uca İş Akışı

Şekil 2 — Uçtan Uca Yaşam Döngüsü



Backend'te uçtan uca desteklenir. Change→Workflow→Approved kısmı frontend'te de doğrulanmıştır.

Roller

Rol	Sorumluluk
Requester	Değişiklik talebi oluşturur, revizyonlar, incelemeye gönderir.
Architect	İş akışında mimari onay adımını yürütür (onay/ret).
QA	Kalite/doğrulama adımlarını değerlendirir.
Release Manager	Yayın planlar, yüksek riskli akışlarda onay verir.
Executor	Onaylı değişikliği hedef ortamda uygular.
Validator	Uygulama sonrası kontrol ve kanıtları toplar.
Auditor	Denetim izlerini ve raporları inceler.
Admin	Kullanıcı/rol/izin yönetimi ve operasyonel kontrol.

Pratik Senaryo (doğrulanmış). Requester "E2E Standart Değişiklik" oluşturdu → backend risk/hazırlık hesapladı → incelemeye gönderildi (*UnderReview*) → "Standart Değişiklik Akışı" başladı ve *Mimari Onay* Architect'e düştü → Architect "Görevlerim"den görevi

tamamladı → iş akışı tamamlandı → Change durumu **Approved** oldu → denetim zaman çizelgesi "Requester User" ve "Architect User" gerçek adlarını gösterdi.

8 Paylaşılan Platform Yetenekleri

GMS, tek amaçlı bir ekran seti değil; **genişletilebilir bir platform** olarak tasarlanmıştır. Aşağıdaki yetenekler her alan tarafından yeniden kullanılır:

Yetenek	Yeniden Kullanım
Authentication / Authorization	Tüm uçlar JWT + izin policy'leriyle korunur.
Current-user kimliği (<code>ICurrentUser</code>)	Aktör her yerde JWT'den çözülür; istemciden gönderilmez.
Durum geçişleri	Change, Release, Workflow, Execution ortak korumalı geçiş desenini kullanır.
Eşzamanlılık (RowVersion)	Kritik varlıklarda kayıp güncelleme koruması.
Numara üretimi	<code>SequentialNumberGenerator</code> ile CHG/REL/WFI numaraları.
Audit (<code>AuditFactory</code>)	Tüm alanlar append-only denetim olayı üretir.
Notification	İş akışı/onay olayları merkezî bildirim motorunu kullanır.
Documents	Paylaşılan doküman + hash + depolama soyutlaması.
Workflow	Change orkestrasyonu ve gelecekte diğer nesneler için ortak motor.
Integration Hub	Dış sistem bağlantıları için sağlayıcı tabanlı ortak katman.
Background workers	Asenkron teslim, SLA hatırlatma, dağıtım — ortak worker temeli.
Reporting	Birleşik denetim görünümü üzerinden ortak raporlama.
Observability	Correlation ID + structured logging + OpenTelemetry her istekte.

9 Veritabanı ve Veri Bütünlüğü

- **SQL Server gerçek kalıcılık katmanıdır** (Docker container, 2022). EF Core InMemory ilişkisel entegrasyon testlerinde kullanılmaz.

- **Göçler (migrations):** 17 adet sıralı migration ile şema sürümlenir (bkz. Teknik Kanıtlar).
- **Yabancı anahtarlar (foreign keys)** ve **benzersiz indeksler (unique indexes)** ile ilişkisel bütünlük.
- **Restrict/Cascade kararları** ilişki türüne göre bilinçli seçilmiştir (örn. denetim/geçmiş kayıtları korunur).
- **RowVersion eşzamanlılık** jetonları kritik varlıklarda (Change, Workflow örneği vb.) mevcuttur.
- **Append-only / değişmez denetim niyeti:** denetim kayıtları güncellenmez, yalnızca eklenir.
- **Sürümlü kayıtlar:** iş akışı tanımları yayımlandığında değişmez (immutable) hâle gelir.
- **Backend domain kalıcılığı için localStorage kullanılmaz;** istemci yalnızca oturum/taslak/tercih saklar.

Bağlantı dizeleri (connection strings) ve kimlik bilgileri bu raporda paylaşılmaz; ortam değişkenleri/gizli anahtarlar ile yönetilir.

10 Güvenlik Kontrolleri

Doğrulanmış Kontroller

- Parola hash'leme
- JWT doğrulama
- Refresh-token rotasyonu
- Hesap kilitleme (logout)
- İzin policy'leri + rol zorlaması
- Nesne/atama düzeyinde zorlama (ör. iş akışı görev ataması)
- Sır şifreleme (secret encryption)
- HMAC webhook doğrulaması
- Hız sınırlama (rate limiting)
- SSRF kontrolleri (giden isteklerde)
- Parola/token/sır loglanmaz
- CSV injection koruması
- Doküman hash (SHA-256) doğrulaması
- Correlation ID izlenebilirliği

Bilinen Üretim-Güvenliği Görevleri (henüz yapılmadı)

- Üretim gizli anahtar yönetimi (secrets)
- HTTPS zorlaması (uçtan uca)
- Kalıcı Data Protection anahtarları (çok düğümlü)
- httpOnly refresh çerezleri (şu an refresh token sessionStorage'da)
- Çok faktörlü kimlik doğrulama (MFA)
- Parola sıfırlama / e-posta doğrulama
- Antivirüs / dosya içerik (magic-byte) taraması

11 Test ve Kalite Sonuçları

Aşağıdaki sayılar depodan doğrulanmıştır (güncel).

Alan	Doğrulama Yöntemi	Sonuç
Backend derleme	dotnet build	0 hata / 0 uyarı*
Backend otomatik testler	xUnit + WebApplicationFactory (gerçek SQL Server)	105 test
Frontend derleme (production)	ng build --configuration production	0 hata / 0 uyarı
Frontend otomatik testler	Vitest (4 spec dosyası)	42 test
Gerçek SQL Server uçtan uca senaryolar	Entegrasyon testleri + manuel/tarayıcı E2E	Başarılı
Arka plan worker testleri	xUnit (BackgroundProcessingTests)	Kapsandı
Entegrasyon mock sunucu testleri	xUnit (IntegrationTests)	Kapsandı

*Backend derleme sonucu, önceki doğrulanmış çalıştırmalara dayanır; bu rapor sırasında backend çalışır durumda olduğundan yeniden derleme yapılmamıştır (çalışan süreç dosya kilidi). Test sayısı 105, kaynak koddaki `[Fact]/[Theory]` sayımıyla doğrulanmıştır.

- **İzole SQL Server test veritabanı:** testler gerçek ilişkisel davranışı doğrular; EF InMemory kullanılmaz.
- **Tarayıcı/manuel frontend E2E:** auth ve Change→Workflow lifecycle gerçek backend'e karşı doğrulandı.
- **Regresyon koruması:** her sprintte mevcut testler yeşil tutuldu (auth 16 + Change/Workflow 26 = 42).
- **Temiz derlemeler:** TypeScript strictness zayıflatılmadı.

12 Çözülen Önemli Teknik Problemler

Aşağıdaki olaylar, mühendislik açısından öğretici örneklerdir (Problem / Kök neden / Çözüm / Öğrenim).

12.1 EF Guid PK ve eşzamanlılık jetonu (ValueGeneratedNever)

Problem: İstemci tarafından üretilen GUID birincil anahtarların (PK) EF tarafından "veritabanı üretiyor" varsayılması. **Kök neden:** varsayılan `ValueGeneratedOnAdd` davranışı. **Çözüm:** `ValueGeneratedNever` ile istemci-üretimi GUID + `RowVersion` eşzamanlılık jetonları netleştirildi. **Öğrenim:** ORM varsayılanları, kimlik ve eşzamanlılık stratejisiyle uyumlu olmalıdır.

12.2 Risk hesabında eksik ortam navigasyonu (navigation)

Problem: Risk hesaplanırken ortam (Environment) ağırlığının hesaba katılamaması. **Kök neden:** ilgili navigation property yüklenmeden risk servisine gidilmesi. **Çözüm:** ortam, risk hesabından önce açıkça yüklendi. **Öğrenim:** hesaplamalar, bağımlı verinin yüklendiğini garanti etmelidir.

12.3 RowVersion çakışma (409) yönetimi

Problem: Aynı kaydın iki kullanıcı tarafından güncellenmesi. **Çözüm:** istemci yüklediği `RowVersion` 'ı geri gönderir; uyuşmazlık 409'a dönüşür; frontend "Güncel veriyi yükle" seçeneği sunar (sessiz üzerine yazma yok). **Öğrenim:** iyimser eşzamanlılık hem backend hem UX'te ele alınmalıdır.

12.4 Broadcast bildirimde numara çakışması

Problem: Toplu bildirim üretiminde ardışık numara çakışmaları. **Çözüm:** numara üretimi ve ekleme sırası çakışmayı önleyecek şekilde düzenlendi. **Öğrenim:** toplu üretimde benzersizlik garantileri kritik.

12.5 SQL raporlamada AVG/alt-sorgu hatası ve CSV BOM sorunu

Problem: Rapor sorgusunda AVG/alt-sorgu çevirisi ve CSV'de Türkçe karakter/BOM. **Çözüm:** sorgu yeniden yazıldı; CSV çıktısına doğru kodlama/BOM ve injection koruması eklendi. **Öğrenim:** raporlama, hem SQL çevirisi hem çıktı güvenliği/kodlaması açısından test edilmelidir.

12.6 İş akışında çift-orkestrasyon kararı (Workflow Strategy A)

Problem: Hem ApprovalService hem Workflow Engine'in yeni Change onaylarını yönetme riski. **Çözüm:** yeni gönderimlerde tek orkestratör olarak Workflow Engine seçildi; Approval kayıtları geçmiş olarak okunur kaldı. **Öğrenim:** iki rakip "doğruluk kaynağı" mimari olarak netleştirilmelidir.

12.7 WebApplicationFactory yapılandırması / test veritabanı

Problem: Entegrasyon testlerinin gerçek SQL Server'a karşı yalıtılmış çalışması. **Çözüm:** `WebApplicationFactory` yapılandırması ve izole test veritabanı ile deterministik testler.

Öğrenim: gerçek ilişkisel davranış, InMemory ile değil gerçek motorla doğrulanmalı.

12.8 Arka plan worker lease / idempotency

Problem: Aynı işin iki worker tarafından işlenmesi. **Çözüm:** lease (kilit) + RowVersion + terminal durum kontrolü + backoff ile çift işleme engellendi (outbox deseni). **Öğrenim:** asenkron işleme idempotent olmalıdır.

12.9 Eşzamanlı 401'lerde tek-uçuş (single-flight) refresh

Problem: Birden çok isteğin aynı anda 401 alıp çoklu refresh tetiklemesi. **Çözüm:** frontend'te `refreshInFlight` + `shareReplay(1)` ile tek refresh paylaşıldı. **Öğrenim:** token yenileme yarış koşullarına (race conditions) karşı koordine edilmelidir.

12.10 Angular baseline derleme hataları ve eksik i18n scope'ları

Problem: Yarım kalmış i18n refactor'ından kaynaklı derleme hataları ve eksik `changes` scope'u (ham anahtarların görünmesi). **Çözüm:** hatalar giderildi, eksik çeviri scope'ları oluşturuldu; bir bileşende eksik `workflows` scope'u E2E sırasında yakalanıp eklendi.

Öğrenim: i18n kapsamı bileşen düzeyinde doğrulanmalı; E2E gerçek boşlukları ortaya çıkarır.

13 Güncel Proje Durumu

Bileşen	Backend	Frontend	Otomatik Test	Gerçek DB	Genel Durum
Identity / RBAC	✓	✓	✓	✓	Tamamlandı
Change	✓	✓	✓	✓	Tamamlandı
Workflow (görev/örnek)	✓	✓	✓	✓	Tamamlandı
Workflow Designer (tanım)	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Release	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Execution	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Validation	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Documents	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Notifications	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Audit / Reports	✓	✗ (mock)	✓	✓	Backend / FE bekliyor
Approval (geçmiş)	✓	✗ (mock)	✓	✓	Kısmi (geçmiş kayıt)
Integration Hub	✓	✗	✓	✓	Backend / FE bekliyor
Background Processing	✓	✗	✓	✓	Backend / FE bekliyor
Observability	✓	n/a	✓	✓	Tamamlandı (altyapı)

■ Tamamlandı ■ Backend tamam / Frontend bekliyor ■ Kısmi ■ Planlandı ✓ mevcut ✗ yok/mock

14 Sonraki Geliştirme Planı (Yol Haritası)

Şekil 3 — Fazlı Yol Haritası

FAZ 1 Aktif	Angular gerçek API entegrasyonu: (1) Change + Workflow Görevleri tamam , (2) Release Planning, (3) Execution + Validation, (4) Documents + Notifications, (5) Audit + Reports, (6) Integration + Operations, (7) Tam frontend E2E ve UX sertleştirme.
FAZ 2 Üretim	Üretim sertleştirme: httpOnly çerez stratejisi, üretim gizli anahtarları, HTTPS, kalıcı Data Protection anahtarları, gerçek SMTP, OTLP collector, merkezî loglama/izleme panoları, yedekleme ve felaket kurtarma (DR), dağıtım hattı (deployment pipeline), veri saklama/temizlik (retention), çok düğümlü worker testleri.
FAZ 3 GxP	GxP / farmasötik yetenekler: elektronik imza, imza anlamı + yeniden kimlik doğrulama, değişmez denetim sertleştirme, ALCOA+, IQ/OQ/PQ, izlenebilirlik matrisi, SOP yönetimi, eğitim kayıtları, sapma (deviation), CAPA, değişiklik etki değerlendirmesi, resmî validasyon paketi.
FAZ 4 Kurumsal	Kurumsal genişleme: çok kiracılık (multi-tenancy), organizasyon/kiracı izolasyonu, Entra ID / SSO, MFA, gerçek Jira/Azure DevOps/GitHub/ServiceNow sağlayıcıları, Teams/Slack, gelişmiş iş akışı yetenekleri, zamanlanmış raporlar.
FAZ 5 AI	Yapay zekâ katmanı: AI risk desteği, değişiklik özetleri, release notları, etki analizi, doğrulama asistanı, denetim inceleme asistanı, semantik arama/RAG.

AI katmanı, **güvenilir veri, güvenlik ve iş akışları** oturduktan sonra gelir.

15 Riskler ve Açık Maddeler

Risk	Güncel Etki	Olasılık	Azaltma (Mitigation)	Öncelik
Frontend modülleri hâlâ mock/localStorage	Bazı ekranlar gerçek veriyi göstermiyor	Yüksek	Faz 1 kademeli entegrasyon	Yüksek
Üretim gizli anahtar yönetimi	Geliştirme anahtarları üretime uygun değil	Orta	Secret store + ortam ayrımı (Faz 2)	Yüksek
Refresh token sessionStorage'da	XSS maruziyet penceresi	Orta	httpOnly çerez (Faz 2); kısa erişim ömrü + rotasyon	Orta
Gerçek SMTP yok	E-posta yalnızca dummy sağlayıcı	Düşük	SMTP sağlayıcı (Faz 2)	Orta
Antivirüs / magic-byte taraması yok	Dosya içerik doğrulaması eksik	Orta	Tarama entegrasyonu (Faz 2/3)	Orta
Yalnızca yerel dosya depolama	Bulut/dayanıklılık yok	Orta	Depolama soyutlaması hazır; bulut sağlayıcı eklenecek	Orta
Sınırlı gerçek sağlayıcı entegrasyonu	Jira/Azure yalnızca sandbox	Orta	Gerçek sağlayıcılar (Faz 4)	Düşük
Resmî GxP uyumu tamamlanmadı	Regülasyonlu kullanım için hazır değil	Yüksek	Faz 3 validasyon paketi	Yüksek
Çok kiracılık yok	Tek kurum varsayımı	Düşük	Faz 4 tenant izolasyonu	Düşük
Operasyonel dağıtım mimarisi kesinleşmedi	Prod topolojisi belirsiz	Orta	Faz 2 pipeline + çok düğüm	Orta

16 Kişisel Katkı ve Öğrenimler

Bu proje boyunca aşağıdaki alanlarda aktif rol aldım:

- Gereksinimlerin netleştirilmesi ve sprint planlaması.
- Mimari kararların değerlendirilmesi ve tartışılması (modüler monolit, orkestrasyon sahipliği, eşzamanlılık stratejisi vb.).
- Yapay zekâ destekli geliştirme için **talimat/istem (prompt) tasarımı** ve kapsam/kısıt belirleme.
- Üretilen kod çıktılarının **gözden geçirilmesi** ve kabul/ret kararları.
- Docker/SQL Server üzerinde **göçlerin (migrations) çalıştırılması ve doğrulanması**.
- Test raporlarının yorumlanması, hataların tespiti ve düzeltme taleplerinin yönlendirilmesi.
- Release / Change / Workflow kavramlarının ve backend↔frontend entegrasyonunun takibi.
- JWT, RBAC, eşzamanlılık (concurrency), denetim (audit), iş akışı, entegrasyon ve arka plan işleme konularında pratik öğrenim.

Şeffaflık notu. Kodun her satırını elle yazdığımı iddia etmiyorum. Geliştirmede yapay zekâ bir **geliştirme asistanı/aracı** olarak kullanılmıştır; ancak **gereksinimler, gözden geçirme, doğrulama ve kararlar** proje ekibi/kullanıcı sorumluluğunda kalmıştır. Katkı; yönlendirme, doğrulama, karar ve entegrasyon takibinde yoğunlaşmıştır.

17 Mentör ile Tartışma Konuları

- Modüler monolit sınırları uygun mu; hangi noktada servis ayrıştırması düşünülmeli?
- Sıradaki entegre edilecek frontend modülü hangisi olmalı (Release mi, Execution/Validation mı)?
- Üretim kimlik doğrulamada httpOnly çerez stratejisine geçilmeli mi?
- Çok kiracılık (multi-tenancy) ne zaman devreye alınmalı?
- Beklenen GxP yetenek seviyesi nedir (hangi ALCOA+/IQ-OQ-PQ kapsamı)?
- Hangi dış entegrasyon önceliklendirilmeli (Jira, Azure DevOps, ServiceNow)?
- Hedeflenen dağıtım ortamı (on-prem, bulut, hibrit) nedir?
- Paydaşlar için en önemli raporlar hangileri?

- İlk pilot için kabul kriterleri (acceptance criteria) ne olmalı?

18 Sonuç

- Backend platform temeli **geniş ve işlevseldir**; on iki alan tamamlanmıştır.
- Çekirdek yaşam döngüsü **gerçek SQL Server** üzerinde çalışır ve testlerle doğrulanır.
- Kimlik doğrulama, yetkilendirme ve paylaşılan platform servisleri **kurulmuştur**.
- Angular kimlik doğrulama temeli **gerçektir**; Change ve Workflow Görevleri gerçek API'ye entegre edilmiştir.
- Mevcut odak, **kademeli frontend API entegrasyonudur**.
- Resmî üretim ve GxP hazırlığı hâlâ **ek fazlar gerektirir**.

Proje, **tıklanabilir bir prototipten (clickable prototype) işleyen modüler bir kurumsal platforma** doğru ilerlemiştir. Sistemin şu anda tam üretime hazır, doğrulanmış (validated) veya regülasyonlu kullanıma uygun olduğu **iddia edilmemektedir**.

EK Teknik Kanıtlar

Aşağıdaki kanıtlar depo incelenerek doğrulanmıştır. Gizli anahtar, parola, token veya bağlantı dizesi içermez.

Depo Yapısı (kök)

backend/ (Gms.Api, Gms.Api.Tests) · frontend/ (gms-ui) · docker-compose.yml ·
sprint raporları (*.md)

Backend Controller Grupları (19)

Auth · ChangeRequests · Approvals · Releases · Deployments · Validations ·
WorkflowInstances · Workflows · Documents · Notifications · Audit · Reports ·
Integrations · IntegrationWebhooks · IntegrationExecutions · Operations ·
Customers · Projects · Environments

Başlıca Servisler

AuthenticationService, TokenService, PasswordService, PermissionService,
ChangeRiskService, ChangeReadinessService, ApprovalService,
ReleasePlanningService, ReleaseRiskService, ExecutionService, ValidationService,
DocumentService, NotificationService, AuditReadService, ReportingService,
ReportExportService, WorkflowDefinitionService, WorkflowRuntimeService,
WorkflowConditionEvaluator, IntegrationService, IntegrationDispatcher,
SequentialNumberGenerator, AuditFactory

Worker'lar (Background)

IntegrationDispatchWorker · NotificationDeliveryWorker · WorkflowSlaWorker ·
OperationalCleanupWorker (ortak BackgroundWorkerBase, WorkerRegistry,
WorkerHeartbeat)

Entegrasyon Sağlayıcıları (Providers)

GenericRestIntegrationProvider · IncomingWebhookIntegrationProvider ·
OutgoingWebhookIntegrationProvider · JiraSandboxProvider ·
AzureDevOpsSandboxProvider · DummySmtipIntegrationProvider (resolver ile)

Veritabanı Göçleri (Migrations, 17)

InitialIdentity → InitialBusinessFoundation → InitialChangeDomain →
ChangeKeysClientGenerated → InitialApprovalDomain → ReleasePlanningDomain →
AddConcurrencyTokens → ExecutionDomain → ValidationDomain →
IdentityAndRbacDomain → DocumentManagementDomain → NotificationEngineDomain →
UnifiedAuditAndReporting → WorkflowEngineDomain → WorkflowRoleGrants →
IntegrationHubDomain → BackgroundProcessingAndObservability

Sağlık ve API Uçları

GET /health · GET /health/live · GET /health/ready · GET /api/operations ·
Swagger UI: /swagger (yalnızca geliştirme) · OpenAPI: /swagger/v1/swagger.json

Frontend Yapısı

23 özellik alanı (features) · 36 core servis · 4 test spec dosyası (app.spec.ts ,
auth.spec.ts , change-integration.spec.ts , workflow-integration.spec.ts)

Doğrulanmış Sayılar

Backend testleri: **105** ([Fact]/[Theory] sayımı) · Frontend testleri: **42** (it() sayımı) ·
Frontend production derleme: **0 hata / 0 uyarı** · Migration: **17**

Belge sonu — GMS Proje İlerleme, Teknik Mimari ve Yol Haritası Raporu v1.0 · Hazırlayan: Mahir Furkan
Dalyan · CENTRA YAZILIM A.Ş. · 16 Temmuz 2026. Tüm veriler depo incelemesiyle doğrulanmıştır; ürün tam
üretime hazır veya GxP-validasyonlu olarak sunulmaz.